

UNIVERSIDAD MAYOR DE SAN ANDRES

Carrera de Informática – Seguridad de la Información



Proyecto: Explotación de Módulos de Autenticación Web - Escudo Pet Spa

Nombre del informe: Informe de Pentesting – posible explotación de seguridad y funcionalidad de módulos de autenticación en entorno local

Materia: Taller Técnico Superior

Analista de seguridad: Limachi Tapia Guillermo

Estudiante revisado: Bernas Carrisales Alejandro Ramiro

Fecha: 31/05/26

Clasificación del documento: Académico / Confidencial

INFORME EJECUTIVO DE VULNERABILIDADES (RV)

Fase de Ejecución, Explotación y Mitigación

Operación Escudo Pet Spa

1. RESUMEN EJECUTIVO

El presente informe documenta la fase de ejecución teórica, simulación ofensiva y evaluación de vulnerabilidades del sistema "Pet Spa", considerando los módulos correspondientes a Administrador, Recepción, Groomer y Cliente.

La evaluación fue realizada mediante análisis de superficie de ataque observable en material audiovisual y revisión conceptual basada en metodologías OWASP Top 10, simulación ofensiva y evaluación de malas prácticas de seguridad.

Debido a limitaciones del entorno, las pruebas fueron desarrolladas bajo un enfoque de explotación hipotética controlada, orientado a identificar posibles escenarios de compromiso, manipulación de lógica de negocio, inyección de código, abuso de carga de archivos y deficiencias en trazabilidad y auditoría.

Los hallazgos identificados evidencian riesgos asociados a:

- Ausencia de CAPTCHA y MFA.
- Validaciones insuficientes en formularios.
- Posibles vulnerabilidades XSS y SQL Injection.
- Deficiencias en RBAC.
- Falta de controles robustos de auditoría.
- Riesgo de saturación de bases de datos.
- Posibles fallas de integridad en inventario y sesiones.

2. OBJETIVOS

2.1 Objetivo General

Evaluar la seguridad ofensiva del sistema Pet Spa mediante simulación de explotación, validación de controles de autenticación, pruebas de lógica de negocio y análisis de vulnerabilidades críticas visibles en la superficie de ataque.

2.2 Objetivos Específicos

- Simular pruebas ofensivas sobre autenticación y sesiones.
- Evaluar posibles escenarios de SQL Injection y XSS.
- Analizar la seguridad de carga de archivos.
- Verificar debilidades de auditoría y trazabilidad.
- Evaluar posibles fallas de lógica de negocio.

- Identificar riesgos de escalación de privilegios.
- Verificar políticas de cifrado y almacenamiento de contraseñas.
- Proponer medidas de mitigación y remediación.

3. ALCANCE

Módulos Evaluados

- Login
- Registro de clientes
- Panel Administrador
- Groomer
- Recepción
- Gestión de usuarios
- Inventario
- Agenda de reservas
- Auditoría y logs
- Gestión de sesiones
- Formularios dinámicos
- Carga de archivos
- Recuperación de contraseña

4. LIMITACIONES DEL ENTORNO

El análisis realizado corresponde a una evaluación teórica y práctica limitada, ejecutada sobre un repositorio clonado en un entorno local (laptop personal). No se contó con acceso a un proyecto desplegado en producción, servidores reales, arquitectura distribuida, APIs funcionales, tráfico HTTP activo ni bases de datos en operación.

Por tanto:

- No fue posible realizar explotación activa sobre un sistema en producción.
- No se pudo interceptar tráfico ni tokens JWT provenientes de un entorno real.
- No se validaron vulnerabilidades en infraestructura distribuida ni mediante payloads activos.
- Sí fue posible utilizar algunas herramientas en entorno controlado para simular ataques y evaluar vectores ofensivos de manera hipotética.

Las conclusiones corresponden a simulaciones ofensivas técnicamente plausibles basadas en la superficie de ataque observable y en pruebas locales realizadas sobre el repositorio clonado.

5. METODOLOGÍA

Metodología Utilizada

- Reconocimiento pasivo
- Análisis de superficie de ataque
- Evaluación OWASP Top 10
- Simulación ofensiva
- Evaluación RBAC
- Threat Modeling
- Simulación de explotación lógica
- Revisión de malas prácticas
- Evaluación de autenticación y sesiones

6. EJECUCIÓN DE PRUEBAS OFENSIVAS

6.1 Pruebas de Lógica de Negocio (Agenda e Inventario)

Vulnerabilidad Evaluada

- Creación masiva de clientes sin validación efectiva.
- Posible manipulación de registros internos.
- Saturación de base de datos mediante automatización.

Tipo de Ataque

- Business Logic Abuse
- Flood de registros
- Parameter Tampering

Superficie de Ataque

- Registro público
- Formularios de usuarios
- Inventario
- Agenda
- Base de datos

Simulación de Ataque

Se simuló teóricamente la automatización de creación de cuentas falsas aprovechando:

- ausencia de CAPTCHA,
- ausencia de límites de registro,
- validaciones débiles.

La superficie observada permite inferir que un atacante podría:

- saturar la BD,
- alterar registros operativos,

- degradar rendimiento del sistema,
- generar inconsistencias de agenda e inventario.

Posible Exfiltración o Impacto

- Saturación de recursos.
- Degradación del servicio.
- Corrupción de inventario.
- Alteración de operaciones internas.

Nivel de Criticidad

Alto

Mitigación

- Rate limiting.
- CAPTCHA adaptativo.
- Restricción de registros.
- Validación backend.
- Monitoreo anti automatización.

6.2 Inyección y Sanitización (SQLi y XSS)

Vulnerabilidad Evaluada

- Formularios administrativos sin validaciones estrictas.
- Inputs arbitrarios.
- Posible ausencia de sanitización backend.

Tipo de Ataque

- SQL Injection
- Stored XSS
- Reflected XSS

Superficie de Ataque

- Formularios administrativos
- Gestión de empleados
- Inputs dinámicos
- Campos de texto libre

Simulación de Ataque

La ausencia visible de validaciones robustas permite inferir viabilidad teórica de:

- inserción de payloads SQL,
- almacenamiento de scripts persistentes,
- bypass de validaciones frontend.

Payload SQLi

' OR '1'='1

Payload XSS

```
<script>alert('XSS')</script>
```

Posible Exfiltración o Impacto

- Acceso indebido a BD.
- Robo de información.
- Corrupción de datos.
- Persistencia de scripts maliciosos.

Nivel de Criticidad

Alto

Mitigación

- Prepared Statements.
- Sanitización backend.
- Escape de caracteres especiales.
- Validación server-side.

6.3 Seguridad en Carga de Archivos

Vulnerabilidad Evaluada

- Posible ausencia de validaciones robustas en carga de archivos.

Tipo de Ataque

- File Upload Attack
- MIME Spoofing
- Double Extension Attack

Superficie de Ataque

- Galería de imágenes
- Upload de archivos
- Formularios multimedia

Simulación de Ataque

Debido a la ausencia visible de controles avanzados:

- se simuló teóricamente carga de archivos maliciosos,
- spoofing MIME,
- doble extensión.

Ejemplo Hipotético

imagen.php.jpg

Posible Exfiltración o Impacto

- Compromiso del servidor.
- Persistencia maliciosa.

- Ejecución remota de código.
- Robo de información.

Nivel de Criticidad

Alto

Mitigación

- Validación MIME real.
- Antivirus.
- Restricción de extensiones.
- Renombrado seguro.
- Almacenamiento fuera del web root.

6.4 Auditoría de Logs y Trazabilidad

Vulnerabilidad Evaluada

- Sistema de logs sin SIEM.
- Dependencia de logs almacenados en BD.

Tipo de Ataque

- Log Tampering
- Log Injection
- Eliminación de evidencias

Superficie de Ataque

- Logs
- Auditoría
- Base de datos
- Panel administrativo

Simulación de Ataque

Se evaluó teóricamente la capacidad del sistema para registrar:

- quién realizó la acción,
- cuándo ocurrió,
- desde qué IP,
- qué acción ejecutó.

La dependencia de logs locales permite inferir riesgo de:

- modificación de registros,
- alteración de evidencias,
- evasión de auditoría.

Posible Exfiltración o Impacto

- Pérdida de trazabilidad.
- Encubrimiento de actividad maliciosa.
- Dificultad de respuesta ante incidentes.

Nivel de Criticidad

Alto

Mitigación

- SIEM centralizado.
- Logs inmutables.
- Integridad criptográfica.
- Correlación de eventos.

6.5 Manipulación de Sesión

Vulnerabilidad Evaluada

- Ausencia de CAPTCHA y MFA en login y registro.
- Posible debilidad de sesiones activas.

Tipo de Ataque

- Session Hijacking
- Credential Stuffing
- Fuerza bruta
- Replay Attack

Superficie de Ataque

- Login
- Gestión de sesiones
- Recuperación de cuentas

Simulación de Ataque

La ausencia visible de:

- MFA,
- CAPTCHA,
- controles anti automatización,

permite inferir viabilidad teórica de:

- secuestro de sesiones,
- reutilización de credenciales filtradas,
- automatización de accesos,
- persistencia de sesión indebida.

Posible Exfiltración o Impacto

- Compromiso de cuentas.
- Acceso indebido.
- Robo de información.
- Persistencia maliciosa.

Nivel de Criticidad

Alto

Mitigación

- MFA obligatorio.
- CAPTCHA dinámico.
- Expiración corta de sesiones.
- Rotación de tokens.
- Cookies HttpOnly/Secure.

6.6 Privacidad de Datos Sensibles

Vulnerabilidad Evaluada

- Posible exposición de información sensible por controles RBAC débiles.

Tipo de Ataque

- Broken Access Control
- IDOR
- Escalación horizontal

Superficie de Ataque

- Gestión de usuarios
- Panel administrativo
- Roles internos

Simulación de Ataque

La debilidad observada en validaciones de roles permite inferir riesgo de:

- acceso indebido a información privada,
- visualización de datos de clientes,
- exposición de información sensible.

Posible Exfiltración o Impacto

- Fuga de datos.
- Violación de privacidad.
- Acceso indebido a información personal.

Nivel de Criticidad

Medio-Alto

Mitigación

- RBAC robusto.
- Validación backend de permisos.
- Restricción estricta de privilegios.
- Auditoría de accesos.

6.7 Validación de Cifrado

Vulnerabilidad Evaluada

- Contraseñas protegidas mediante hashing.
- Riesgo asociado a algoritmos débiles o configuraciones insuficientes.

Tipo de Ataque

- Cracking Offline
- Rainbow Tables

Superficie de Ataque

- Base de datos
- Sistema de autenticación

Simulación de Ataque

Se evaluó la resistencia del almacenamiento de credenciales frente a:

- cracking offline,
- ataques de diccionario,
- rainbow tables.

La implementación de hashing reduce significativamente el riesgo de exposición directa.

Posible Exfiltración o Impacto

- Compromiso parcial de credenciales.
- Reutilización de contraseñas.
- Acceso no autorizado.

Nivel de Criticidad

Bajo

Mitigación

- Mantener algoritmos modernos.
- Migrar a Argon2id.
- MFA obligatorio.
- Incrementar costo computacional del hash.

7. CLASIFICACIÓN GENERAL DE CRITICIDAD

Alto

- SQL Injection
- XSS persistente
- Session Hijacking
- Ausencia de MFA
- Registro masivo automatizado
- Logs sin SIEM
- File Upload Attack
- Contraseñas por defecto

Medio

- Debilidades RBAC
- Recuperación de contraseña insuficiente
- Validaciones frontend insuficientes

Bajo

- Riesgo reducido por hashing implementado
- Exposición parcial limitada mediante almacenamiento hash seguro

8. CONCLUSIONES GENERALES

La evaluación realizada sobre el repositorio clonado en entorno local permitió identificar múltiples superficies de ataque con viabilidad teórica de explotación bajo escenarios reales. Aunque no se contó con acceso a un sistema desplegado en producción ni fue posible ejecutar explotación activa, las simulaciones ofensivas evidencian condiciones potencialmente vulnerables frente a amenazas comunes descritas en el **OWASP Top 10**.

Los hallazgos más relevantes se concentran en:

- **Abuso de lógica de negocio** mediante creación masiva de registros sin controles anti-automatización.
- **Inyección y sanitización insuficiente** en formularios administrativos, con riesgo de SQLi y XSS persistente.
- **Carga insegura de archivos**, susceptible a spoofing MIME y ejecución remota.
- **Deficiencias en auditoría y trazabilidad**, con riesgo de manipulación de logs y pérdida de evidencias.
- **Debilidades en gestión de sesiones**, ausencia de MFA y CAPTCHA, facilitando ataques de fuerza bruta y secuestro de sesión.
- **Controles RBAC insuficientes**, con riesgo de acceso indebido a información sensible.
- **Protección criptográfica parcial**, donde el uso de hashing reduce el riesgo, pero requiere fortalecimiento con algoritmos modernos.

La clasificación general de criticidad ubica la mayoría de vulnerabilidades en nivel Alto, destacando SQLi, XSS, hijacking de sesión, ausencia de MFA, registros masivos automatizados, logs sin SIEM y ataques de carga de archivos. Se identificaron también riesgos Medio asociados a RBAC y validaciones insuficientes, y un riesgo Bajo vinculado al almacenamiento hash de contraseñas.

En conclusión, el sistema presenta una superficie de ataque amplia y condiciones que, bajo un despliegue real, podrían comprometer la confidencialidad, integridad y disponibilidad de los datos y servicios. Se recomienda priorizar la implementación de MFA obligatorio, validaciones backend robustas, sanitización estricta, monitoreo centralizado con SIEM, segmentación de privilegios y controles avanzados de carga de archivos, como medidas críticas para reducir la exposición frente a amenazas comunes y mejorar la resiliencia general de la plataforma.